

Cybergistplanet
Vulnerability Assessment and Penetration

By
Chukwuebuka Asogwa

Disclosure Statement

This document is subject to the terms and conditions of a non-disclosure agreement between I, Chukwuebuka Asogwa and Cybergistplanet.

I, a private Vulnerability accessor and Penetration Tester has prepared this confidential document for the customer. This document shall be treated at all times as confidential. Portions of this document and the templates used in its production are my property. No part of this document may be reproduced, copied, or modified (in whole or part) without me or my customer's consent.

While precautions have been taken in preparing this document, I, the publisher, and the author assume no responsibility for errors, omissions, or damages resulting from the use of the information contained herein.

Chukwuebuka Asogwa
greenebuks@gmail.com | 08116245920

Table of Contents

Disclosure Statement	2
Document Stakeholders	4
Document Version History	4
Executive Summary	5
Objective	5
Scope.....	5
Penetration Test Details.....	5
Disclaimer and Limitations	6
Penetration Testing Process	7
Approach and Methodology	7
Identification of Vulnerabilities	8
Attack Narrative:	9
Graphical Representation of Vulnerabilities.....	10
Summary of Key Findings.....	11
Detailed Finding.....	12
1. Lack of Sanitization of Block Import that allows for stored XSS that Leads to RCE via User Browsers.....	12
General Comments and Security Advice.....	13
Implement Centralized Filtering Method Potential	13
Conclusion and Roadmap	14

Document Details

Document Stakeholders

Role	Name of Stakeholder	Designation
Reviewer – CYBERGISTPLANET	Mr Kayode	CEO, CYBERGISTPLANET

Document Version History

Document Version	Comment	Date
1.0	Final Report	14 th January, 2025

Executive Summary

I Chukwuebuka Asogwa, an independent Vulnerability Assessor and Penetration Tester was commissioned to accomplish this assessment. As a Penetration tester, I am accountable for the identification, analysis, and evaluation of the security issues found during the testing. I also doubled as the Project Manager who is responsible for the project plan, project monitoring, controlling project documentation, and providing high-quality deliverables. This assessment was performed remotely by the me, and the assessment started on 4th of January 2025 and concluded on 8th January 2025. I and the Cybergistplanet team decided to use the grey box penetration testing methodology and approach for this assessment.

The tests were carried out by identifying vulnerabilities with the intent of gaining access to critical information. The objective of performing this activity was to assess the security risks associated with the developed application and service and identify vulnerabilities that could be leveraged by cybercriminals to compromise the application and its services.

The security test results and findings provided in this report are valid for the period during which the assessment was carried out and are based on the information provided for the assessment. The findings in this report reflect the conditions found during the assessment and do not necessarily reflect current conditions.

During the penetration testing, I reported 23 different vulnerabilities within 6 different plugins which include the following:

- **Critical** 04
- **High:** 05
- **Medium** 09
- **Low:** 05

Objective

The purpose of this assessment was to:

1. Test the **Cybergistplanet Web Application** (Cybergistplanet.com) to identify technical vulnerabilities and discover whether an attacker may leverage these flaws to compromise the security of Cybergistplanet Web Application.
2. Provide recommendations for risk mitigation that may arise on successful exploitation of these vulnerabilities.

Scope

Following digital assets are considered as the scope of work. The security assessment was performed using the below asset scope as agreed upon with the client.

Scope Details
Company Portal https://cybergistplanet.com

Penetration Test Details:

Activity	Dates
WPScan - II	8 th January 2025
Nessus Scan - II	7 th January 2025
WPScan – I	6 th January 2025
Nessus Scan - I	5 th January 2025
Asset Reconnaissance (Un-interactive)	4 th January 2025

Disclaimer and Limitations

Only one major blocker was encountered during the test blockers were encountered during this can. A **Cloudflair Web Application Firewall** was refusing the scan but this was very easily bypassed by a simple extra query in the command line.

I do not offer any form of representation, warranty, or guarantee that the systems are 100% secure from every form of a cyber-attack. My methodology for this assessment was automated testing to identify the most common security issues, testing was limited to an agreed schedule and timeframe. The application was tested for all known vulnerabilities or public vulnerabilities and not every vulnerability may have been identified.

1. Denial of service issues that could potentially disrupt the Client environment was not tested.
 - A. I did not test vulnerabilities that would intentionally lead to denial of service issues in an effort to prevent operational disruptions to the Client environment.
2. Social Engineering
 - B. Social Engineering attacks were not in scope for this assessment.

Penetration Testing Process

As a security professional, I follow a penetration testing methodology that aligns with industry best practices including the following:

- NIST SP 800-115 Technical Guide to Information Security Testing and Assessment of Federal Information
- OWASP Top Ten and OWASP ASVS 4.0.2
- Penetration Testing Execution Standard (PTES)
- Payment Card Industry Information Supplement: Requirement 11.3 Penetration Testing

My Vulnerability Assessments and Penetration tests are scaled to meet the needs of the organization and help the organization in identifying the high business risk vulnerabilities in the provided scope of work.

Approach and Methodology

The assessment was completed as per my proprietary standard security best practices including OWASP, SANS, and NIST standards and frameworks. my penetration testing is scaled to meet the needs of the organization and helps the organization identify the high business risk vulnerabilities in the given scope of work. The below section describes the approach and methodology followed during the penetration testing.

The general overview of our methodology is as follows:



The OWASP Top Ten/ OWASP ASVS 4.0.2 list of vulnerabilities that are included for this vulnerability assessment:

- A01:2021 - Broken Access Control
- A02:2021 - Cryptographic Failures
- A03:2021 - Injection
- A04:2021 - Insecure Design
- A05:2021 - Security Misconfiguration
- A06:2021 - Vulnerable and Outdated Components
- A07:2021 - Identification and Authentication Failures
- A08:2021 - Software and Data Integrity Failures
- A09:2021 - Security Logging and Monitoring Failures
- A10:2021 - Server-Side Request Forgery

Identification of Vulnerabilities:

I use industry frameworks such as OWASP ASVS 4.0, SANS, NIST 800-115, and out of box test cases for identifying the critical to low vulnerabilities in the agreed scope of work. Cybergistplanet can be sure that the most recent and common web application vulnerabilities peculiar with the environment will be tested during this vulnerability scan.

Evaluation of Vulnerability:

After understanding the vulnerability next step is to evaluate or rank the vulnerability by determining the risk magnitude, which is the combination of likelihood and consequence. Evaluate the vulnerability on the 5-level Severity scale from Informational, Low, Medium, High and Critical. In addition, the report also provides but is not limited to decisions about whether the vulnerability is acceptable or whether it is serious enough to warrant treatment.

The following priority matrix was used to classify the structure of assessment findings:

Priority Level	Severity Scale	CVSS Score	Description of Vulnerability
P1	Critical	9.0-10.0	Vulnerabilities that affect all users of the platform, and/or affect the security of the platform or host system(s).
P2	High	7.0-8.9	Vulnerabilities that affect more than one user of the platform, and that require little or no user interaction to trigger.
P3	Medium	4.0-6.9	Vulnerabilities that affect more than one user but may also require interaction or a specific configuration.
P4	Low	0.1-3.9	Issues that affect individual users and require interaction or significant prerequisites (MITM) to trigger.
P5	Informational	0.0	Issues that leaking very basic information which might lead to information disclosure.

Attack Narrative:

Overview

This document provides information on the narrative and description of the weaknesses which were exploited to gain unauthorized access to sensitive data or protected systems in the Client environment via Web Application Penetration Testing. The intent was to closely simulate an adversary and provide sufficient details to Company Name Team.

Research and Exploitation

The information below describes the tests and coverage achieved for the Web Application Penetration Testing of the given Product Application scope. The section comments on enumerated approaches taken to investigate various components and areas of the items in scope. I began the Vulnerability Test by passively reviewing the application's underlying public infrastructure and architecture. The following are the details of the testing:

Scope URLs:

As a WordPress application without client account, ecommerce or user dynamic interaction functionalities, heavily focused on the third-party plugins used in the application. With these we could identify plugins that were out of date and vulnerable and components that even though well updated are still vulnerable to attack.

This test was achieved by very extensive enumeration of all the components of the application. The URL details played a key role in this exposure and visible functions on the pages particularly the 403 pages were also indicative of the presence of these components.

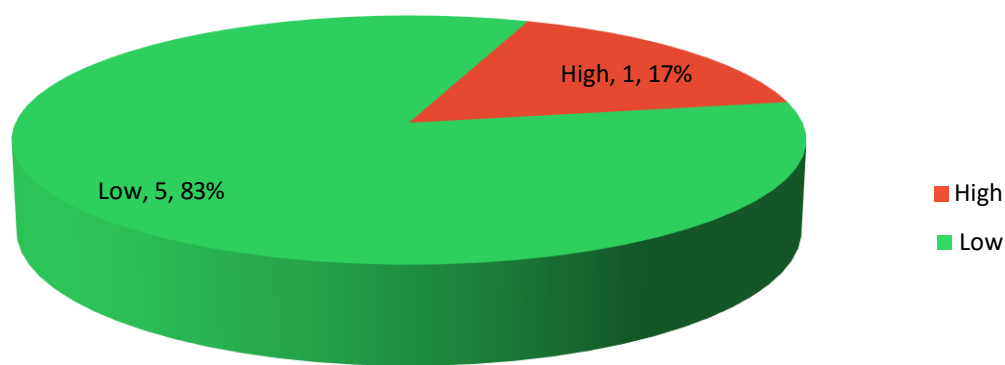
A very critical security flaw in the application lack of input sanitization.

Since this test was only to identify, I do not have the liberty of exploiting these vulnerabilities.

Many of the plugins used on the application are out of date and have known vulnerabilities which puts the organization at risk of even low skilled script kiddies.

Graphical Representation of Vulnerabilities:

This section highlights the graphical representation of the vulnerability severity discovered during the assessment:



Summary of Key Findings

The assessment uncovered some security flaws and some of them required urgent attention.

Finding ID #	Plugin Name	Vulnerability Title	Severity Level	CVSS Score	Status
#VP001	Astra-sites	Lack of Sanitization of Block Import that allows for stored XSS that Leads to RCE via User Browsers.	High	7.6	Open

Detailed Finding

The below sections list the detailed technical description of the identified vulnerabilities, possible mitigation strategies with references, security risk, and step-by-step details to reproduce the vulnerabilities.

1. Lack of Sanitization of Block Import that allows for stored XSS that Leads to RCE via User Browsers.

Description
The application is vulnerable to privilege escalation vulnerability on the application IAM user module. This vulnerability allows an attacker to disable an account owner account via the low-level user role of Data Owner, which doesn't intend to happen.

Astra-sites (Theme)	7 Vulnerabilities Found	1
CVSS	Starter Templates < 2.7.1 - Contributor+ Block Import to Stored XSS	Risk Rating
7.6	Vector String	High
	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:L	

Module Name	Affected Resource
Plugin	https://cybergistplanet.com

Security Risk
The security impact of this vulnerability is reported as High, considering the exploitability. The following are the considerable security impacts: - Users with any editor capability can import block onto any page using the astr-page-elementor-batch-process AJAX action. - Remote code execution in the browser of site visitors. - Any page built with Elementor can be overwritten by the imported Block

Workaround/Mitigation
It is strongly recommended to fix this vulnerability and implement the following: - This vulnerability exists because the impute field does not sanitize imported blocks, allowing malicious java scripts to be executed when content is viewed or interacted with. - Log into your WordPress site as an administrator ⇒ Navigate to Plugins ⇒ Installed Plugins - Look for Starter Templates and note the version installed - If it is below 2.7.1, the site is vulnerable - Temporarily deactivate the plugin to prevent exploitation until the issue is fixed. - Go to Plugins > Installed Plugins, find Starter Templates, and click Deactivate

- Update the plugin and Confirm the update installs **version 2.7.1** or higher.
- Check for Exploitation: Verify all users with the **Contributor** role or higher. Remove or downgrade unnecessary accounts.
 - Look for suspicious scripts in posts, pages, or imported blocks.
 - Common indicators include `<script>` tags, `onerror`, `onload`, or `javascript:` in attributes.
- Secure against Future Incidents:
 - Limit User Roles: Ensure only trusted users have Contributor, Author, or higher roles.
 - Install a Security Plugin: Use plugins like **Wordfence, Sucuri, or iThemes Security** for monitoring and protection
- Implement a CSP via your hosting or plugin to prevent inline scripts from executing.
- Restrict Imports: Review settings in Starter Templates to control which users can import blocks/templates.
- Regularly check your plugins for updates.
 - Monitor security advisories for the Starter Templates plugin and other plugins/themes
- Test the updated plugin:
 - Re-enable the plugin and verify its functionality.
 - Import blocks/templates to ensure they are sanitized correctly
- Train team members and site contributors on the importance of security.
 - Emphasize careful handling of imports, especially from external sources.
-

References

- | - <https://wpscan.com/vulnerability/f7f2e9f9-685d-42ba-bde1-01372c9c7c73>
- | - <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2021-42360>
- | - <https://www.wordfence.com/blog/2021/11/over-1-million-sites-impacted-by-vulnerability-in-starter-templates-plugin/>

General Comments and Security Advice

Implement Centralized Filtering Method Potential

It is recommended to use a centralized filtering method for all values that can be tampered by adversaries and actors other than the potentially affected user. This holds for the search function and the url. The instances might be tampered with by motivated attackers. Therefore, a centralized filter tool that would continuously ensure proper output filtering for any incoming byte-string is urged, as it would assist in keeping the Application and any upcoming versions of the tool as safe and secure as possible.

Source Code Audit

Source Code Audit/Review was not in scope of the Vulnerability testing.

Conclusion and Roadmap

The primary goals of this vulnerability scan were to identify whether or not the **cybergistplanet.com** Web Application has adequate controls in place to protect against unauthorized access to the website and potential exposure of sensitive information of its users, by both external and internal attackers.

To achieve these goals, we performed an extensive scan done twice daily for five days during low traffic time to wholistic view of the environment. After repeated scans with different tools, we conclude the target application security posture as below:

Application	Overall Security Posture
Cybergistplanet.com	Medium

In the above table, the overall security posture is calculated at medium level for the scope application service. This evaluation depends upon the vulnerability impact on the business objectives.

It should be noted that this was a point-in-time assessment and that **Cybergistplanet** Team should perform regular security assessments as changes are made to the application and supporting infrastructure. The actual risk posed by these findings may be less than what is indicated due to mitigating factors such as use case, technical, and administrative controls.